

N.D.C

Session 1: Introduction to Information Security

Introduction to Information Security

- Information Security (InfoSec) refers to the processes and methodologies designed to protect sensitive information from unauthorized access, disclosure, alteration, or destruction.
- It ensures confidentiality, integrity, and availability (CIA Triad) of data.
- Involves securing digital and physical information assets.

Why Information Security?

- To prevent data breaches, protect sensitive information, and avoid financial losses.
- Builds trust among customers, stakeholders, and partners.
- Compliance with legal and regulatory standards such as GDPR, HIPAA, etc.
- Safeguards intellectual property and organizational reputation.

Security: The Money Factor Involved

- **Financial Losses:** Cyberattacks, ransomware, and data breaches can result in significant monetary damage.
- **Cost of Prevention vs. Cost of Breach:** Investing in security is often cheaper than dealing with the aftermath of an incident.
- **Insurance:** Cybersecurity insurance has become a significant cost consideration for organizations.
- **Revenue Impact:** Security lapses can lead to customer attrition and loss of future revenue.

Internet Statistics - Study from a Security Perspective

- **Daily Threats:** Millions of malware samples are created daily.
- **Data Breaches:** Billions of records are exposed annually.
- **Growth of IoT:** The increasing number of IoT devices expands the attack surface.
- **Social Engineering:** Human error accounts for a significant percentage of breaches.
- **Dark Web:** Data is traded, emphasizing the need for robust security.

Vulnerability, Threat, and Risk

- **Vulnerability:** A weakness in a system that can be exploited (e.g., unpatched software).
- **Threat:** A potential cause of harm, such as malware or hackers.
- **Risk:** The likelihood of a threat exploiting a vulnerability, causing damage.
- **Risk Equation:** $\text{Risk} = \text{Threat} \times \text{Vulnerability} \times \text{Impact}$.

Quality of Service (QoS)

- Ensures reliable and efficient network performance.
 - **QoS Parameters:** Bandwidth, latency, jitter, and packet loss.
 - **Security Aspect:** QoS tools can mitigate Distributed Denial of Service (DDoS) attacks and prioritize critical traffic.
-

Session 2: Risk Management and Firewalls

Risk Management, Exposure, and Countermeasure

- **Risk Management:** Identifying, assessing, and mitigating risks.
- **Exposure:** The extent of potential loss or harm from a risk.
- **Countermeasure:** Security controls or mechanisms to reduce risk (e.g., encryption, firewalls).

Firewall

- A security device or software that monitors and controls incoming and outgoing network traffic based on predetermined rules.
- Protects networks from unauthorized access and cyber threats.

De-Militarized Zone (DMZ)

- A physical or logical subnet that separates an organization's internal network from untrusted external networks (e.g., the internet).
- Hosts public-facing services (e.g., web servers) while minimizing risk to the internal network.

Two Methods of Implementing Firewalls

1. **Hardware Firewalls:**
 - Standalone devices designed for network protection.
 - High performance but expensive.
 2. **Software Firewalls:**
 - Installed on individual systems or servers.
 - Cost-effective and flexible but resource-intensive.
-

Session 3: Advanced Firewall Concepts and iptables

Packet Filtering

- Examines each packet's header information and decides whether to allow or block it.
- Works at the network layer of the OSI model.
- Rules are based on IP addresses, ports, and protocols.

Screened Host Firewall

- Combines a router (with filtering rules) and a bastion host.
- The bastion host is exposed to external networks and provides controlled access to internal networks.
- Enhances security by layering defenses.

Stateful Inspection Firewall

- Monitors the state of active connections and uses this context to make filtering decisions.
- Tracks the state of each connection (e.g., TCP handshake) to ensure legitimacy.
- More secure than packet filtering due to context awareness.

NextGen Firewall App Controls

- Combines traditional firewall functionality with advanced features like:
 - Application awareness and control.
 - Intrusion prevention systems (IPS).
 - Deep packet inspection (DPI).
 - Threat intelligence integration.
- Designed to combat modern, sophisticated threats.

iptables - Linux Firewall

- A command-line utility in Linux for managing firewall rules.
- Operates on the Netfilter framework in the Linux kernel.
- Key Concepts:
 - **Chains:** Input, Forward, Output.
 - **Rules:** Allow or block traffic based on criteria (IP, port, protocol).
 - **Targets:** ACCEPT, DROP, REJECT.
- Common Commands:
 - Add a rule: `iptables -A [CHAIN] -p [PROTOCOL] -d [DESTINATION] --dport [PORT] -j [TARGET]`.
 - List rules: `iptables -L`.
 - Delete a rule: `iptables -D [CHAIN] [RULE_NUMBER]`.

Session 4: Wireshark and Packet Analysis

Wireshark:

- Wireshark is a widely-used network protocol analyzer that captures and inspects packets in real time.
- It is an essential tool for troubleshooting network issues, analyzing traffic, and identifying security threats.

- Features include deep inspection of hundreds of protocols, live capture, and offline analysis.

Creating Filters for Data Collection and Display:

- Filters in Wireshark allow you to focus on specific traffic or isolate particular network problems.
 - **Capture Filters:** Specify what type of traffic is recorded during a capture. Example: `tcp port 80` (captures only HTTP traffic).
 - **Display Filters:** Used to analyze captured packets. Example: `ip.src == 192.168.1.1` (displays packets originating from a specific IP address).
 - Combine filters using logical operators: `&&`, `||`, and `!` for AND, OR, and NOT.

Examining Real-World Packet Captures:

- Analyze traffic to identify patterns, errors, or suspicious activity.
 - Example use cases:
 - Diagnosing slow application performance.
 - Detecting unauthorized access or malicious traffic.
 - Understanding protocol usage, like DNS queries or HTTP requests.
-

Session 5: Linux Software Firewall and Proxy Servers

Linux Software Firewall (ClearOS, Pfsense):

- **ClearOS:** A user-friendly Linux-based firewall with a web-based interface for managing network security, content filtering, and intrusion prevention.
- **Pfsense:** An open-source firewall and router platform offering advanced features like VPN support, load balancing, and customizable rules.
- Both tools enable network administrators to manage traffic efficiently and secure networks against threats.

Nginx & Squid Reverse Proxy:

- **Nginx:** A high-performance web server and reverse proxy used for load balancing, caching, and securing web applications.
- **Squid:** A caching and forwarding HTTP proxy that reduces bandwidth usage and improves response times.
- Reverse proxies add an extra layer of security by hiding backend servers and distributing incoming traffic.

Unified Threat Management (UTM):

- UTM refers to integrated network security solutions combining firewall, intrusion detection, anti-virus, content filtering, and VPN in a single appliance.
- Benefits include simplified management, cost efficiency, and comprehensive threat protection.

Server Load Balancing:

- Distributes incoming traffic across multiple servers to ensure availability and reliability.
 - Techniques include round-robin, least connections, and IP hash methods.
 - Load balancers can be hardware-based or software-based (e.g., HAProxy).
-

Session 6 & 7: VPN Concepts and Protocols

VPN Introduction:

- A Virtual Private Network (VPN) extends a private network across a public network, ensuring secure data transmission.
- VPNs use encryption and tunneling protocols to protect sensitive data.

VPN Protocols/Characteristics:

- Common VPN protocols:
 - **PPTP:** Fast but less secure.
 - **L2TP/IPsec:** Secure with strong encryption.
 - **OpenVPN:** Highly secure and flexible, uses SSL/TLS.
 - **IKEv2:** Stable and efficient, especially for mobile devices.
- Characteristics include encryption strength, authentication methods, and compatibility.

VPN Functions:

- Encrypt data to ensure privacy.
- Allow remote access to private networks.
- Provide secure connections for corporate or personal use.

Types of VPN:

- **Remote Access VPN:** Connects individual devices to a private network.
- **Site-to-Site VPN:** Connects entire networks to each other.
- **Mobile VPN:** Designed for users on mobile devices or changing networks.

SecureVPN & Trusted VPN:

- **SecureVPN:** Uses strong encryption and authentication to ensure data integrity and confidentiality.
 - **Trusted VPN:** Relies on secure private lines instead of encryption but offers limited flexibility.
-

Session 8: Advanced VPN Topics

Hybrid VPN:

- Combines features of SecureVPN and Trusted VPN to balance security and efficiency.

IPsec:

- Internet Protocol Security (IPsec) is a suite of protocols for encrypting and authenticating IP packets.
- Modes:
 - **Tunnel Mode:** Encrypts the entire IP packet, including headers.
 - **Transport Mode:** Encrypts only the payload, leaving headers visible.

IPv6 VPN:

- Extends VPN capabilities to IPv6 networks, ensuring compatibility with modern internet infrastructure.

Split Tunnel and Full Tunnel VPN:

- **Split Tunnel:** Allows users to send specific traffic through the VPN while accessing other resources directly.
 - **Full Tunnel:** Routes all traffic through the VPN for maximum security.
-

Session 9: Intrusion Detection and Prevention Systems (IDS/IPS)

Introduction to IDS and IPS:

- **IDS:** Monitors network traffic for suspicious activity and generates alerts.
- **IPS:** Similar to IDS but also takes action to block or mitigate threats.

Types of Attacks:

- Examples include:
 - Denial of Service (DoS).
 - Man-in-the-Middle (MITM).
 - SQL Injection.
 - Malware and ransomware.

Security Events:

- Refers to logs and alerts generated by IDS/IPS during suspicious or malicious activity.
- Helps identify trends, vulnerabilities, and potential breaches.

Vulnerability Design and Implementation:

- Identifying and addressing weaknesses in system architecture.

- Involves regular vulnerability assessments, patch management, and adherence to security best practices.

Session 10 & 11: IDS and IPS Overview

Attacks - Traditional/Distributed

1. **Traditional Attacks:**
 - Single-source origin attacks targeting vulnerabilities in systems or networks.
 - Examples: Brute force attacks, phishing, malware infections, and SQL injection.
 2. **Distributed Attacks:**
 - Multiple systems (botnets) used to coordinate attacks.
 - Examples: Distributed Denial of Service (DDoS), amplification attacks, and distributed scanning.
-

Intruder Types

1. **External Intruders:**
 - Unauthenticated users attempting unauthorized access.
 - Motivations: Theft, vandalism, or espionage.
 2. **Internal Intruders:**
 - Authorized users exploiting privileges.
 - Examples: Employees stealing data, privilege escalation attacks.
-

Types of IDS (Intrusion Detection Systems)

1. **Network-Based IDS (NIDS):**
 - Monitors network traffic for anomalies.
 - Positioned at strategic points within the network.
 2. **Host-Based IDS (HIDS):**
 - Monitors activity on individual hosts or devices.
 - Analyzes system logs, file integrity, and configurations.
 3. **Hybrid IDS:**
 - Combines NIDS and HIDS capabilities.
 - Provides a broader detection scope.
-

IPS Categories (Intrusion Prevention Systems)

1. **Network-Based IPS (NIPS):**
 - Operates at the network level.

- Blocks malicious traffic based on signatures or anomalies.
 - 2. **Host-Based IPS (HIPS):**
 - Runs on individual endpoints.
 - Prevents attacks on specific devices or applications.
 - 3. **Wireless IPS (WIPS):**
 - Secures wireless networks.
 - Detects rogue devices and unauthorized connections.
-

Defence in Depth

1. **Definition:**
 - Multi-layered security approach to protect assets.
 - Layers include: Physical, network, application, and endpoint security.
 2. **Benefits:**
 - Increased redundancy.
 - Minimized risk from single-point failures.
-

IDS and IPS Analysis Scheme

1. **Stages:**
 - Data Collection: Gathering traffic/logs.
 - Detection: Identifying anomalies or signatures.
 - Response: Alerts or active blocking.
 2. **Tools Used:**
 - Snort, Suricata, Zeek (formerly Bro).
-

Detection Methodologies

1. **Signature-Based Detection:**
 - Matches patterns of known threats.
 - Limitation: Cannot detect zero-day attacks.
 2. **Anomaly-Based Detection:**
 - Identifies deviations from normal behavior.
 - Limitation: High false-positive rates.
 3. **Behavioral Analysis:**
 - Tracks patterns of user or system behavior.
-

Principles of IDS

1. Accuracy: Minimize false positives and negatives.
2. Efficiency: Real-time detection with minimal latency.

3. Scalability: Handle increased traffic loads.
-

Threat Hunting Model

1. **Steps:**
 - Hypothesis Development: Based on threat intelligence.
 - Data Collection: Logs, traffic, and endpoint data.
 - Analysis: Correlate findings.
 - Remediation: Patch vulnerabilities or strengthen defenses.
-

Session 12 & 13: Advanced IDS Concepts

Symptoms of Attacks

1. Unusual traffic patterns.
 2. Unauthorized system access.
 3. Unexpected system crashes or slowdowns.
 4. Altered system files.
-

Tiered Architecture

1. **Three Tiers:**
 - **Presentation Layer:** User interface.
 - **Logic Layer:** Data processing and analysis.
 - **Data Layer:** Data storage and retrieval.
-

Sensors - Network/Host-Based

1. **Network Sensors:**
 - Capture and analyze packets on a network.
 - Examples: Taps, port mirroring.
 2. **Host-Based Sensors:**
 - Installed on devices to monitor activities.
-

Denial of Service (DoS)

1. **Definition:** Overloading resources to render services unavailable.
2. **Types:** Application-layer, volumetric, and protocol attacks.

DoS & DDoS Mitigation

1. **Approaches:**
 - Rate Limiting.
 - Blackholing.
 - Traffic Filtering.
 - Cloud-based mitigation services (e.g., Cloudflare, Akamai).

Sensor Deployment

1. Strategic placement in high-risk zones.
2. Ensure coverage of critical assets.

Agents

1. **Definition:**
 - Software components in HIDS that gather data.
2. **Functions:**
 - Log monitoring, file integrity checks, and policy enforcement.

IDS Manager

1. Centralized control and monitoring.
2. Functions:
 - Alert aggregation.
 - Policy updates.
 - Data correlation.

Session 14: SIEM and Log Analysis

Introduction of Log Analyzer

1. **Purpose:**
 - Centralized log collection and analysis.
 2. **Benefits:**
 - Identify trends and correlations.
 - Enhance forensic investigations.
-

Logs

1. Types: System logs, application logs, security logs.
 2. Key Elements: Timestamps, source, severity, and description.
-

SIEM Log Correlation and Event Triggering

1. **Correlation Rules:** Identify related events across sources.
 2. **Event Triggering:** Generate alerts for predefined conditions.
-

Introduction of SIEM

1. **Definition:**
 - Security Information and Event Management system.
 2. **Functions:**
 - Real-time monitoring, correlation, and reporting.
-

SIEM Log Forwarding Configuration

1. Steps:
 - Configure log sources.
 - Define forwarding rules.
 - Test and validate configurations.
-

Session 15: Practical IDS Concepts

Testing Snort in Both Windows & Linux

1. **Setup:**
 - Install Snort on both platforms.
 - Configure rules and test network traffic.
 2. **Analysis:**
 - Monitor alerts.
 - Evaluate performance differences.
-

IDS Architecture

1. Components:
 - Data Collection.

- Detection Engine.
 - Management Console.
-

Bypassing an IDS

1. Techniques:
 - Encrypted traffic (e.g., TLS/SSL).
 - Fragmented packets.
 - Obfuscated payloads.
2. Prevention:
 - Deep Packet Inspection (DPI).
 - Protocol-aware detection.